GRC205: INCIDENT MANAGEMENT AND BUSINESS CONTINUITY

Crisis Communication And Stakeholder Management

Crisis Communication Response Pack

Scenario: Ransomware during payroll week

Student name: Ocen Richard

Registration number: 2025/GCR/12742

Submission date: November 6th, 2026

1. One-page incident communication plan

Situation (08:15 Monday): The critical file share is unavailable. Several teams cannot access shared files. Ransomware is suspected but not confirmed. Payroll processing is scheduled for Friday and may be delayed. An unverified screenshot is circulating. The security team is preserving evidence and investigating (GRC105 course materials, 2026).

Communication objective: Protect people and essential operations, establish one verified picture, give practical instructions, and maintain a predictable update rhythm. Communication is part of incident response, not a post-incident public-relations activity (GRC105 course materials, 2026; Nelson et al., 2025).

Command and approval

- Incident commander: sets priorities, approves escalation, and owns decision cadence.
- Communications lead: maintains the message log, drafts audience-specific updates, and releases only approved information.
- Technical lead: verifies affected systems, containment status, evidence, and recovery estimates.
- Legal/compliance lead: checks legal duties, privilege, contractual obligations, and regulator engagement.
- HR/People lead: coordinates employee instructions and confirms receipt.
- Spokesperson: the only person authorized to speak publicly.

Single source of truth: Maintain a time-stamped incident log with four labels: confirmed, unknown, assumption, and next verification. Record the source and responsible technical owner for each entry. Keep internal working notes separate from approved messages. Preserve evidence and use a secure out-of-band copy if corporate systems are unavailable (GRC105 course materials, 2026; Nelson et al., 2025).

First communication cycle (08:30 to 12:30)

Time	Communication / audience	Purpose and key content	Owner
08:30	Incident command alignment: incident commander, technical, legal, HR, communications	Confirm facts and unknowns; appoint spokespersons; open the incident log; approve disclosure rules; agree next review at 09:00.	Incident commander
09:00	Employee holding statement	Explain file-share disruption; address screenshot without validating it; prohibit forwarding; give safe reporting and fallback instructions; set next update at 10:30.	Communications + HR
10:00	Executive and payroll/banking partner briefing	Explain operational exposure, payroll cut-off milestones, containment status, decisions required, and next review at 12:00.	Incident commander + Finance
11:00	Customer update, if customer services are affected or likely to be affected	State confirmed service impact, available support route, what is being checked, and next update time. Do not disclose unverified cause or data exposure.	Account lead + Communications

Escalation rule: Any single high-severity signal triggers crisis-lead escalation. High signals include core service or payroll disruption, outage exceeding four hours or no reliable recovery estimate, public/media/regulator attention, credible evidence of personal-data access, or material legal/safety

exposure. Medium signals require increased monitoring and a named decision owner. This is a proposed operational threshold for the scenario, not a statutory test.

Update rhythm: issue the next update at the promised time even if the position has not changed. State what is known, what remains unknown, actions underway, what recipients must do, and when the next update will be issued.

2. Stakeholder map

Stakeholder	**Information they need**	**Action requested**	**Message owner**	**Cadence / channel**
Direct workforce	Service availability, safe work instructions, payroll process status, screenshot guidance.	Do not forward screenshot; report suspicious messages; use approved fallback procedures; acknowledge receipt.	HR / People lead	Initial SMS and manager cascade by 09:00; updates every 90 minutes or on material change.
Executive leadership and board	Operational impact, payroll exposure, legal and financial risks, options, decisions and dependencies.	Approve resources, business continuity priorities, risk appetite, and external messaging.	Incident commander	Brief at 10:00; review at 12:00 and on any high-severity trigger.
Key customers / B2B clients	Whether contracted services are affected, continuity arrangements, support route, next update.	Use stated support route; report service failures; avoid sharing unverified claims.	Account lead	At 11:00 if impact is confirmed or reasonably expected; then at agreed checkpoints.
Regulator / legal counsel	Verified incident chronology, potential personal-data impact,	Advise on notification, preservation, privilege, and	Legal / compliance lead	Immediate legal assessment; notify the relevant authority when the

Stakeholder	Information they need	Action requested	Message owner	Cadence / channel
	containment, evidence, and applicable duties.	contractual/regulatory obligations.		statutory threshold is met.
Banking and payroll clearing partners	Payroll file availability, transaction boundaries, cut-off times, reconciliation and contingency options.	Confirm deadlines, alternate secure submission methods, and whether processing can proceed.	Finance / payroll lead	Direct secure contact by 10:00; confirm receipt and milestones at each change.
IT, security and recovery teams	Affected assets, indicators, isolation status, evidence handling, dependencies and restoration priorities.	Preserve logs, avoid destructive changes, verify scope, and report status through the incident log.	Technical lead	Continuous technical updates; formal command review at least hourly.

The map follows the lecture's principle that each group needs different information and a named owner. It also includes the assignment's required cohorts and the operational partners who can affect payroll continuity (GRC105 course materials, 2026).

3. First employee holding statement (150–200 words)

At 08:15 this morning, a number of teams became unable to access the organisation's shared file service. Our security team is investigating the disruption and preserving relevant evidence. Ransomware is one possibility being assessed; the cause, scope, and any effect on information have not yet been confirmed.

You may have seen a screenshot circulating in staff chats. It has not been verified. Do not forward, repost, comment on, or act on the screenshot. Send the original message and its source to the IT service desk or the designated incident reporting contact using the approved channel. Do not delete relevant messages or attempt to investigate the issue yourself.

Use approved alternative work procedures and contact your line manager if a task is blocked. Do not connect unknown USB devices, open unexpected attachments, or use personal accounts to transfer organisational files. Payroll is scheduled for Friday, but we cannot yet confirm whether processing will be affected. We are checking the payroll timeline with Finance and our processing partners. The next staff update will be issued by 10:30 through the emergency SMS channel and manager cascade. Only the appointed spokesperson may comment externally.

This statement acknowledges the disruption, separates suspicion from confirmed facts, gives clear actions, and commits to a specific next update (GRC105 course materials, 2026; Cybersecurity and Infrastructure Security Agency [CISA], 2024).

4. Customer / partner update (100–150 words)

We are investigating a disruption affecting access to an internal file service. At this stage, we have not confirmed the cause or established that customer information or customer-facing services have been affected. Our security and operations teams are preserving evidence, assessing the scope, and checking dependencies that could affect service delivery. If your service is affected, please use your existing account contact or the verified support number in your contract. Do not send sensitive information or credentials in response to unsolicited messages referring to this incident. We will provide a further update by 11:00, or sooner if a material verified change occurs. We will distinguish confirmed information from matters still under investigation.

Release only after the account lead confirms whether the recipient's service is affected and the communications lead and legal adviser approve the wording.

5. Executive briefing

As at 10:00 Monday - Prepared by the communications lead for the incident commander

- Confirmed: The critical file share became unavailable at 08:15. Several teams cannot access shared files. The security team is preserving evidence and investigating. Payroll is scheduled for Friday.
- Unknown: Whether ransomware is present; the entry point; the number of affected systems; whether data was accessed or exfiltrated; the recovery time; and whether payroll will miss a processing cut-off.
- Key risks: Payroll delay, operational interruption, evidence loss, misinformation, contractual impact, possible personal-data breach, and inconsistent external statements.
- Decisions required: Confirm the business continuity method for payroll; authorize required technical and external response resources; approve the spokesperson and customer communication trigger; direct legal review of notification duties.
- Partner checks: Finance must confirm bank and payroll clearing cut-off times, secure alternate submission methods, and the last safe decision time for Friday processing.

- Next checkpoint: 12:00 Monday. The communications lead will issue an update even if there is no material change.

Legal note: If the organisation believes personal data has been accessed or acquired by an unauthorised person, section 23 of Uganda's Data Protection and Privacy Act requires notification to the Authority in the prescribed manner. Regulation 33 of the 2021 Regulations states that the notification is to be made immediately after the breach and specifies the information to include. Legal counsel and the data protection officer should assess the facts and applicable obligations promptly. The current scenario does not establish that personal data has been accessed (Data Protection and Privacy Act, 2019, s. 23; Data Protection and Privacy Regulations, 2021, reg. 33).

6. Channel-resilience plan

Audience	**Primary channel**	**Fallback channel**	**Owner**	**Receipt confirmation**
Employees	Corporate collaboration tool / email, if trusted and available	Pre-registered SMS broadcast and manager phone tree	HR lead	SMS delivery report plus manager roll-call / acknowledgement
Executives	Approved incident bridge on a trusted platform	Direct phone calls and pre-agreed out-of-band bridge	Incident commander	Verbal read-back of decisions; decision log entry
Customers	Externally hosted status page and verified account email	Contract-listed support phone line and account manager calls	Account lead	Ticket acknowledgement or account-manager confirmation
Regulator / legal	Official regulator portal or verified official email, as advised by counsel	Telephone contact followed by formal documented submission	Legal / compliance lead	Submission receipt and timestamp retained
Payroll / banking partners	Pre-agreed secure partner portal or authenticated contact	Verified phone contact and approved alternate secure transfer method	Finance / payroll lead	Partner read-back of cut-off and written confirmation

Do not use a channel merely because it is available. Verify the recipient and channel independently, especially if identity services or corporate email may be compromised. Maintain offline contact lists, use externally hosted status infrastructure, and require human confirmation for critical instructions. A message without confirmation is treated as undelivered (GRC105 course materials, 2026; Nelson et al., 2025).

7. Escalation rationale (approximately 250 words)

The incident is escalated to the crisis lead when a high-impact signal appears because the event has moved beyond a technical fault into a business continuity and stakeholder-management problem. The critical file share is already unavailable to several teams, and payroll has a fixed Friday deadline. A prolonged outage, uncertainty about recovery, or failure to meet a payroll cut-off could affect employees, contractual commitments, financial operations, and confidence in the organisation. Public circulation of an unverified screenshot also creates an information vacuum that can quickly generate rumours. The lecture identifies service impact, duration, and external exposure as escalation signals and recommends escalation when any single high signal is reached (GRC105 course materials, 2026).

The response therefore uses a precautionary crisis-management posture while keeping factual claims limited. The team can say that access to a shared file service is disrupted, that investigation and evidence preservation are underway, and that payroll dependencies are being checked. It cannot yet say that ransomware is confirmed, identify an attacker or entry point, quantify affected systems, state that data was stolen, promise a recovery time, or guarantee Friday payroll. Those matters require technical or operational verification. The screenshot must be described as unverified rather than repeated as fact.

The legal team must assess whether evidence meets Uganda's personal-data breach notification threshold. The Act and Regulations should guide that assessment, but the organisation must not announce a data breach merely because ransomware is suspected (Data Protection and Privacy Act, 2019, s. 23; Data Protection and Privacy Regulations, 2021, reg. 33). This approach balances speed with accuracy: communicate early, give useful instructions, document decisions, and update at fixed times. It avoids false reassurance while allowing leaders to act before every technical question is answered.

8. Critical reflection (approximately 150 words)

The most difficult communication decision was how to reassure employees about Friday payroll without making a promise that the incident team could not support. Employees need timely and clear information because uncertainty can increase anxiety and encourage rumours. However, promising that payroll will proceed could mislead staff, damage trust, and create legal or operational problems if the payroll systems or partner cut-off times are later found to be affected. I therefore separated the confirmed file-share disruption from the unverified ransomware suspicion and stated that payroll was scheduled for Friday but

its status was still being checked. I also gave employees practical instructions, a reporting route, and a definite time for the next update. This approach accepts that the first message may not answer every question. It prioritises honest, useful communication over unsupported reassurance. Regular updates can reduce uncertainty while preserving the organisation's ability to correct its position as verified facts emerge.

Assumptions and review notes

This response pack treats the scenario facts as the only confirmed incident facts. The named roles, proposed update times, severity thresholds, communication channels, and partner arrangements are operational proposals because the assignment does not identify the organisation's actual staff, systems, contracts, or service providers.

References

Cybersecurity and Infrastructure Security Agency. (2024, February 1). *Incident response plan basics*. https://www.cisa.gov/sites/default/files/2024-02/Incident-Response-Plan-Basics_508c_1Feb2024.pdf

Data Protection and Privacy Act, 2019, Act 9 of 2019 (Uganda). https://ict.go.ug/ims/public/site/documents/Data-Protection-and-Privacy-Act-2019.pdf

Data Protection and Privacy Regulations, 2021, Statutory Instrument No. 21 of 2021 (Uganda). https://pdpo.go.ug/media/2022/03/Data_Protection_and_Privacy_Regulations-2021.pdf

GRC105 course materials. (2026). *Crisis communication is an operational control*. Unpublished course material.

Nelson, A., Rekhi, S., Souppaya, M., & Scarfone, K. (2025). *Incident response recommendations and considerations for cybersecurity risk management: A CSF 2.0 community profile (NIST SP 800-61 Rev. 3)*. National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-61r3